

Student Problem Statements – Cyber Security

After your impressive audit in Part 1, the college IT department has invited you to contribute to a new project: working on the data center security.

Many applications are hosted in the enterprise datacenter as well as public cloud today. Most applications and "workloads" are hybrid - meaning that the application uses services in both the private data center and public cloud. Since data has to exit the private data center to reach the public cloud, there must be strong network security and segmentation. The cloud security functionality (such as aws' security groups and IAM) form a significant factor in providing this security.

Modern applications also use kubernetes orchestrated containers and microservices to provide highly scalable, cloud native services. These kubernetes orchestrated applications can be present in both private data centers using technology such as openshift or in public cloud using GKE, EKS or AKE.

When a new application has to be deployed, multiple stakeholders are now needed - application developers, network designers, kubernetes platform engineers, etc.

Faculty members also now work flexibly from home or campus, and require uninterrupted, secure access to teaching tools, research repositories, and internal services to applications that are running in hybrid mode - private datacenter services connected to services in the public cloud.

Your task is to design a secure hybrid datacenter network architecture that supports applications connecting or using services between private datacenter and public cloud. How should IAM function? What kind of security groups must be utilized? How can applications be segmented in VPCs such that we can mitigate any attack on a single application from spreading into other applications, VPCs or into the enterprise network itself.

Can your design balance simplicity, security, and scale without overwhelming the existing infrastructure?

Cyber Security

Secure Hybrid Data Center Network Architecture

Procedure-1

A Zero-Trust, defense-in-depth architecture for secure connectivity between private data centers, public cloud, applications, and Kubernetes workloads.

CORE PRINCIPLE

A compromised application must not automatically become a compromised enterprise.

Prepared as a proposed solution to the Cisco Virtual Internship 2026 Student Problem Statement – Cyber Security.

1. Executive Summary

The proposed solution uses Zero Trust, least privilege, network segmentation, cloud-native security controls, Kubernetes micro-segmentation, centralized monitoring, and defense in depth. Private data-center workloads and public-cloud workloads communicate through controlled, encrypted connectivity rather than a flat trusted network.

- Centralized identity with SSO, MFA, RBAC and contextual access decisions.
- Application-level remote access through ZTNA instead of broad network access.
- Separate VPCs/VNETs and security zones for different applications and trust levels.
- Default-deny security groups and firewall policies using least-privilege rules.
- Kubernetes namespaces, RBAC and NetworkPolicies to restrict east-west workload movement.
- Centralized logs, SIEM/SOC monitoring, alerting and incident response.
- A secure deployment workflow that involves developers, network engineers, cloud engineers, Kubernetes engineers and security teams.

2. Security Objectives

- Protect private data-center resources and public-cloud workloads.
- Allow only explicitly approved communication between applications.
- Prevent lateral movement after an application or workload is compromised.

- Secure faculty access from campus and home without exposing the entire enterprise network.
- Provide scalable security controls without creating unnecessary operational complexity.
- Maintain visibility across users, endpoints, network, cloud, Kubernetes and applications.

3. Proposed High-Level Architecture

Users → MFA + Device Verification → ZTNA / Secure Access → IAM / Policy
 ↓
 Security Enforcement → Firewall + NAC + Segmentation

Private Data Center ↔ Encrypted IPsec / SD-WAN / Dedicated Connectivity ↔ Public Cloud

Private DC: DMZ | Application Zone | Database Zone | Kubernetes Zone | Management Zone
 Cloud: Transit / Firewall | VPC-A | VPC-B | Shared Security Services
 Kubernetes: Namespace + RBAC + NetworkPolicy + Service Identity

All environments → Central Logging / SIEM / SOC

4. Network and Security-Zone Segmentation

The network should not be built as one large trusted address space. Security zones reduce the blast radius of an intrusion and make policy easier to reason about.

Zone	Purpose	Internet	Database Access
User	Faculty/students/end users	Controlled	No direct access
DMZ	Public-facing services	Limited	No direct access
Application	Backend services	Controlled	Only approved paths
Database	Sensitive data	No	N/A
Zone	Purpose	Internet	Database Access
Kubernetes	Containerized workloads	Controlled	Policy-based
Management	Administrative systems	Restricted	Privileged only
Security/Logging	SIEM, monitoring, telemetry	Controlled	Read/collect
Backup	Backup and recovery	No	Restricted

5. Hybrid Cloud Connectivity

The data center should connect to the cloud through an encrypted and controlled path. Connectivity should provide reachability where required, but connectivity itself must never imply trust.

- Use IPsec VPN for an initial or smaller deployment.
- Use dedicated connectivity such as AWS Direct Connect, Azure ExpressRoute or Google Cloud Interconnect when scale and availability justify it.
- Use SD-WAN where multiple sites, cloud environments and policy-driven routing are required.
- Place firewalls/security inspection points on both sides of the hybrid boundary where appropriate.
- Route only required prefixes and explicitly permit only required application flows.

6. VPC / VNET Segmentation

Applications with different risk, ownership or data sensitivity should not share one unrestricted VPC. A transit architecture can provide controlled connectivity while preserving isolation.

Network	Example Workload	Key Controls
VPC-A	Student Portal	Private subnets, SGs, WAF/LB
VPC-B	Faculty Portal	Private subnets, SGs, IAM
VPC-C	Examination System	Stricter isolation, DB protection
VPC-D	Research Application	Restricted egress, separate IAM
Shared Services	DNS, logging, monitoring	Centralized, least privilege

7. IAM, RBAC and Zero Trust

IAM determines who a user or workload is and what it is permitted to access. Network controls determine which communication paths are actually reachable. These controls should complement each other.

- Central identity provider with SSO.
- MFA for all privileged accounts and sensitive applications.
- RBAC for faculty, students, developers, network administrators, Kubernetes administrators and security staff.
- Use contextual/attribute-based decisions where appropriate: device posture, location, risk, application and time.
- Do not grant developers production database access unless explicitly required.
- Use short-lived credentials and service identities where practical.
- Review and remove stale privileges periodically.

8. Faculty Remote Access

Faculty working from home should receive application-level access rather than broad access to the enterprise network. A ZTNA/Secure Access model verifies identity, MFA, device posture and policy before connecting the user to an approved application.

9. Security Groups and Firewall Policy

Source	Destination	Port	Decision	Reason
--------	-------------	------	----------	--------

Internet	Web/LB	443	ALLOW	Public HTTPS
Source	Destination	Port	Decision	Reason
Web SG	App SG	8080	ALLOW	Approved application flow
App SG	DB SG	5432	ALLOW	Database access
Internet	DB SG	Any	DENY	No direct database exposure
Student VPC	Exam VPC	Any	DENY	Prevent lateral movement
App	K8s API	Any	DENY	No unnecessary cluster control
Admin subnet	Management	Approved	ALLOW	Privileged administration

Policy principle: default deny. If a flow is not explicitly required, it should not be allowed.

10. Kubernetes and Micro-Segmentation

- Separate applications into Kubernetes namespaces.
- Use Kubernetes RBAC to limit administrative actions.
- Use NetworkPolicies to restrict pod-to-pod and pod-to-external communication.
- Use separate service accounts and least-privilege permissions.
- Protect secrets and avoid embedding credentials in images or source code.
- Use image scanning, admission policies and runtime monitoring in the deployment pipeline.
- Use TLS/mTLS for sensitive service-to-service communication where appropriate.

Workload	Allowed	Blocked
Student-App	Student DB, approved services	Faculty-App, Exam-App
Faculty-App	Faculty DB, approved services	Student-App, Admin
Exam-App	Exam DB, approved services	Other applications
Research-App	Research DB, approved services	Enterprise admin network

11. Secure Application Deployment Workflow

1. Requirements & Risk Analysis
2. Application Classification
3. Choose Data Center / Cloud Placement
4. Create VPC/VLAN/Network Segment
5. Define IAM, RBAC and Service Identities
6. Define Security Groups and Firewall Rules
7. Define Kubernetes Namespace and NetworkPolicies
8. Security Testing and Approval
9. Production Deployment
10. Continuous Monitoring and Periodic Review

12. Multi-Stakeholder Responsibilities

Team	Primary Responsibility
Application Developer	Secure application code, dependencies, APIs and secrets
Security Team	Threat model, security requirements, risk acceptance and policy
Network Engineer	Routing, segmentation, firewall and connectivity
Cloud Engineer	VPC/VNET, cloud infrastructure and cloud controls
Kubernetes Engineer	Clusters, namespaces, RBAC and NetworkPolicies
IAM Team	Identity, MFA, roles, access lifecycle
SOC	Monitoring, detection, investigation and incident response
Change Management	Production approval and controlled changes

13. DevSecOps Integration

Security should be integrated into the application delivery pipeline instead of being performed only after deployment.

- Source control → CI/CD → SAST → dependency scanning → secret scanning.
- Container image scanning before deployment.
- Infrastructure-as-Code security checks.
- Policy validation before production.
- Kubernetes admission controls and runtime monitoring.
- Continuous logging and security alerting after deployment.

14. Attack Scenario and Blast-Radius Containment

Scenario: an attacker obtains a faculty credential and later compromises a research application.

- MFA and device/risk checks challenge suspicious access.
- If the attacker reaches the research application, VPC and application segmentation restrict access to other applications.
- Security groups allow the research application to reach only its approved backend/database.
- Kubernetes NetworkPolicies block unauthorized east-west movement.
- RBAC prevents the compromised workload from administering the cluster.
- Firewall policies block direct access to management and enterprise networks.
- Central monitoring detects abnormal authentication, network and workload activity.

Compromised Research App

Research DB ✓ | Student App X | Exam App X | Admin Network X | K8s Control Plane X

15. Monitoring and Incident Response

- Collect identity, endpoint, firewall, cloud, Kubernetes and application telemetry.
- Monitor failed logins, privilege escalation, unusual API calls, security-group changes and abnormal traffic.

- Detect port scanning, lateral movement and suspicious data transfer.
- Centralize logs in a SIEM/SOC workflow.
- Create alerts for high-risk changes and suspicious workload behavior.
- Maintain incident-response playbooks for credential compromise, workload compromise and data exfiltration.

16. Cisco Technology Mapping

Security Requirement	Possible Cisco Technology / Capability
Network firewalling	Cisco Secure Firewall
Firewall management	Secure Firewall Management Center
Identity / NAC	Cisco ISE
Remote application access	Cisco Secure Access / ZTNA
Workload segmentation	Cisco Secure Workload
Network telemetry / analytics	Cisco Secure Network Analytics
Secure connectivity	Cisco SD-WAN
Threat intelligence	Cisco Talos
Cloud security	Cisco cloud security capabilities + native cloud controls

Note: the architecture should be technology-neutral at the control level. Cisco products should be selected based on the college's existing infrastructure, budget, operational skills and deployment requirements rather than deploying every product by default.

17. Scalability and Simplicity

- Standardize a small number of network/VPC patterns rather than creating a unique design for every application.
- Use reusable security-group and firewall policy templates.
- Automate infrastructure and policy deployment where practical.
- Use centralized identity and logging to avoid isolated security silos.
- Start with the highest-risk applications and expand segmentation gradually.
- Prefer clear default-deny rules over large collections of exceptions.

18. Final Security Model

Principle	Implementation
Zero Trust	Verify identity, device, context and application access
Least Privilege	Minimum permissions for users and workloads
Default Deny	Only explicitly required traffic is allowed
Segmentation	Zones, VPCs, namespaces and security groups
Defense in Depth	IAM + firewall + endpoint + workload + monitoring
Continuous Verification	Ongoing risk and behavior monitoring
Visibility	Central logs, SIEM and SOC

Conclusion: The proposed architecture balances simplicity, security and scale by using centralized identity, segmentation, least-privilege connectivity and continuous monitoring. Its main security outcome is blast-radius reduction: compromise of one application or workload should not automatically provide a path to other applications, cloud networks or the enterprise network.

Secure Hybrid Datacenter Network Architecture

Procedure-2

Designing Network Security, Segmentation & IAM for Hybrid Cloud Workloads

College IT Department – Cyber Security Project | Student Reference Guide

19. Problem Context

Modern college applications are hybrid: they use services in both the private data center and public cloud (AWS, Azure, GCP). Data must leave the private data center to reach the cloud, so strong network security and segmentation are essential. Applications increasingly run as Kubernetes-orchestrated containers and microservices (OpenShift on-prem; EKS, GKE, or AKS in the cloud). Faculty also require secure remote access to teaching tools, research repositories, and internal services.

Core design challenges: How should IAM function? What security groups must be used? How can applications be segmented in VPCs so that an attack on one application cannot spread to other applications, VPCs, or the enterprise network? The solution must balance simplicity, security, and scale without overwhelming existing infrastructure.

20. Design Goals

- **Hybrid connectivity** — Secure, resilient links between private data center (OpenShift) and public cloud (EKS / GKE / AKS).
- **Strong segmentation** — Contain blast radius so compromise of one application cannot reach others or the enterprise core.
- **Consistent IAM** — Least-privilege identity and access across on-prem and cloud.
- **Kubernetes-aware security** — Network policies, pod security, and optional service mesh.
- **Secure remote access** — Faculty can work from home or campus without exposing the internal network.
- **Practical balance** — Security and scale without excessive complexity for a college environment.

21. Recommended Architecture Overview

The design follows a **Zero-Trust + Hub-and-Spoke** model. A central Hub (Landing Zone / Shared Services VPC) connects to multiple Spoke (Application) VPCs. Hybrid traffic between the private data center and cloud

is forced through inspection points. Default-deny policies apply at every layer (network, security groups, Kubernetes NetworkPolicy).

Layer	Private Data Center	Public Cloud
Network zones	Management, Application, Shared Services, DMZ (firewall / SDN micro-segmentation)	Hub VPC + multiple Spoke (Application) VPCs; Transit Gateway / Hub-Spoke topology
Kubernetes	OpenShift with NetworkPolicy + SCC / Pod Security	EKS / GKE / AKS with NetworkPolicy + Pod Security Standards (Restricted)
Connectivity	Next-gen firewall edge; no direct app subnet exposure	Direct Connect / ExpressRoute / Interconnect + redundant IPsec VPN
Identity	Central IdP (AD / Azure AD / Okta / Keycloak)	Federated IAM (IAM Identity Center, Azure AD, Cloud Identity) + workload identity

Table 1: High-level hybrid architecture components

22. Network Foundation & Hybrid Connectivity

Private Data Center

Segment the private data center into clear zones (Management/Jump, Application/Workload, Shared Services, DMZ/Edge). Control east-west traffic with micro-segmentation (next-generation firewall rules or OpenShift SDN + NetworkPolicy). Application workloads should not have unrestricted access to management or shared-services zones.

Public Cloud Layout

- **Landing Zone / Hub VPC** — Shared services, transit, centralized inspection, logging, and connectivity to on-prem.
- **Spoke (Application) VPCs** — Prefer one application (or tightly related set of microservices) per Spoke VPC for strongest blast-radius control.
- Use Transit Gateway (AWS), Cloud Router + Shared VPC / peering (GCP), or Virtual WAN / Hub-Spoke (Azure).
- Prefer **PrivateLink / Private Service Connect / Private Endpoints** over public internet or even broad VPC peering for most service-to-service traffic.

Hybrid Links

Primary path: dedicated connection (AWS Direct Connect, Azure ExpressRoute, Google Cloud Interconnect) or high-quality IPsec VPN with redundant tunnels. All hybrid traffic must pass through a security inspection point (cloud-native firewall or appliance + on-prem next-gen firewall). Do not allow direct routing of application subnets into the enterprise core without explicit policy and inspection.

23. Segmentation Strategy (Containment)

Segmentation is the primary control that stops an attack on one application from spreading. Apply it at three levels:

VPC/network, security groups / NSGs, and Kubernetes NetworkPolicy.

VPC / Network Level

- One application (or closely related group) per Spoke VPC where practical.
- Inside each VPC: public subnets only for load balancers / ingress; private subnets for workloads and Kubernetes nodes; data-tier subnets with no internet route and tightly restricted sources.
- No transitive routing between Spoke VPCs by default. Cross-application communication only via inspected Hub path, PrivateLink/Private Service Connect, or an approved API/service-mesh gateway.

Security Groups / Network Security Groups

- **Default deny** on all security groups / NSGs.
- Prefer security-group references over CIDR ranges (e.g., App-SG allows ingress only from ALB-SG on 443; DB-SG allows ingress only from App-SG on 5432).
- Separate security groups for: Kubernetes control plane, worker nodes, ingress/load balancer, application pods/node groups, and data stores.
- Place cloud-native firewalls (AWS Network Firewall, Azure Firewall, Google Cloud Firewall) in the Hub for centralized policy and logging.
- Mirror the same least-privilege model on-prem with equivalent firewall rules.

Kubernetes Layer

- Enforce **NetworkPolicy** (Calico, Cilium, or cloud CNI) on every cluster — default deny ingress and egress; allow only required pod-to-pod, pod-to-service, and specific egress destinations.
- Apply **Pod Security Standards (Restricted)** or equivalent (OpenShift SCC, Kyverno / OPA Gatekeeper).
- Consider a service mesh (Istio, Linkerd, etc.) for mTLS between services, fine-grained authorization, and controlled multi-cluster traffic.
- Multi-cluster communication should use service-mesh multi-cluster or cloud-native multi-cluster networking with strict policy — never flat networking.

24. Identity and Access Management (IAM)

IAM must be consistent across on-prem and cloud, based on least privilege, federation, and short-lived credentials.

Core Principles

- Central identity provider (college AD / Azure AD / Okta / Keycloak) as source of truth.
- Federation via SAML / OIDC into cloud IAM (AWS IAM Identity Center, Azure AD, Google Cloud Identity).
- Least privilege + just-in-time (JIT) access where possible.
- No long-lived access keys. Prefer roles, workload identity, and short-lived credentials.

Workload Identity

Kubernetes pods should assume cloud roles without storing secrets: use IRSA (EKS), Workload Identity (GKE), Workload Identity Federation (AKS/Azure), or equivalent. Map service accounts to specific IAM roles with minimal permissions (e.g., read only one S3 bucket, access only specific secrets).

Human Access

- **Faculty / staff:** SSO + MFA into a Zero Trust Network Access (ZTNA) service or application proxy. Prefer application-level access over full-network VPN.
- **Administrators / platform engineers:** Just-in-time elevation via PAM or temporary cloud credentials + session recording.
- **Developers:** Scoped to their application's namespace / VPC via Kubernetes RBAC + IAM conditions.
- Use organization-level guardrails (AWS SCPs, Azure Management Groups, GCP Organization policies) and permission boundaries so even privileged users cannot create overly permissive resources or open broad security groups.

25. Remote Faculty Access

Traditional full-tunnel VPN is no longer the preferred primary method. Use Zero Trust Network Access (ZTNA) or an application proxy so that faculty reach only the specific teaching tools, research repositories, and services they need.

- Mandatory MFA and device posture checks (managed device, current OS, endpoint protection).
- Access granted only to specific applications/services, not the entire network.
- Session logging and continuous evaluation of trust.
- Fallback resilient connectivity so teaching and research are not interrupted by network issues.

26. Supporting Controls (Must-Have)

- Centralized logging and monitoring: CloudTrail / Activity Logs, VPC Flow Logs, Kubernetes audit logs, and SIEM correlation.
- Continuous compliance and posture management (CSPM) plus regular vulnerability scanning.
- Secrets management (HashiCorp Vault, cloud Secrets Manager, External Secrets Operator) — never store secrets in code or plain ConfigMaps.
- Encryption in transit (TLS 1.2 or higher) and at rest for all sensitive data.
- Regular attack-path and lateral-movement testing (red / purple team exercises focused on segmentation).

27. How the Design Mitigates Attack Spread

Scenario	Control that Contains It
Application workload compromised	Limited to its Spoke VPC and its own security groups / NetworkPolicies
Lateral movement inside the VPC	NetworkPolicy + security-group default-deny block unnecessary east-west traffic

Attempt to reach other applications	No transitive routing; cross-VPC only via inspected Hub or PrivateLink with extra controls
Attempt to reach private data center core	Hybrid traffic inspected; no direct unrestricted routes into enterprise core
Stolen credentials / role abuse	Least-privilege IAM + workload identity + permission boundaries limit what a compromised workload can do
Compromised faculty endpoint	ZTNA is application-scoped; endpoint has no broad network access

Table 2: Containment of common attack scenarios

28. Balancing Simplicity, Security, and Scale

- Start with a clean Hub-and-Spoke model plus strong default-deny security groups and NetworkPolicies — high security with manageable complexity.
- Avoid excessive VPC proliferation at the beginning; group related low-sensitivity applications if needed, then tighten over time.
- Re-use the existing college identity provider and logging infrastructure.
- Automate with Infrastructure-as-Code and Policy-as-Code so the model scales without proportional operational load.
- Phased rollout reduces risk and allows the team to learn the operating model.

29. Recommended Implementation Steps

Follow a phased approach so that security improves continuously without disrupting teaching and research.

Step 1. Establish centralized identity federation and enforce MFA for all administrative and remote access.

Step 2. Build the Landing Zone / Hub VPC and hybrid connectivity with traffic inspection.

Step 3. Define organization-wide guardrails (SCPs / org policies, default-deny security-group templates, NetworkPolicy baselines).

Step 4. Create the first Spoke VPC and Kubernetes cluster with NetworkPolicy and workload identity enabled.

Step 5. Migrate one non-critical application; validate segmentation, logging, and access paths.

Step 6. Roll out ZTNA (or equivalent secure remote access) for faculty.

Step 7. Expand to additional applications; enforce continuous monitoring and Policy-as-Code.

Step 8. Conduct regular red-team / purple-team exercises focused on lateral movement and segmentation effectiveness.

30. Key Takeaways for Students

- Hybrid cloud requires explicit design for the boundary between private data center and public cloud — do not rely on perimeter security alone.
- Segmentation (VPC isolation + security groups + Kubernetes NetworkPolicy) is the most effective way to limit blast radius.
- IAM must be federated, least-privilege, and workload-identity aware; long-lived keys and broad roles are high risk.

- Default-deny at every layer is simpler to reason about and safer than trying to list every allowed path after the fact.
- Faculty remote access should be application-scoped (ZTNA) rather than full-network VPN as the primary method.
- Automation (IaC + Policy-as-Code) and continuous monitoring are required to keep the architecture maintainable at scale.

This document is a student reference for the Cyber Security hybrid datacenter design exercise. Apply the principles to your own lab or project environment and always validate controls with testing.